

ARKE — Pente fino de prontidão

Varredura de 21 de setembro de 2026 · branch `claude/arke-multitenant-reset-8c8xw3`

Atualização da noite de 21/09. Depois que este relatório foi gerado, os itens do lado ARKE foram executados: os cinco defeitos de vínculo duplo corrigidos e publicados, o gêmeo morto do parser removido, os advisors fechados e a causa da orfandade *provada*. O documento foi atualizado para mostrar o que caiu e o que sobrou — cada achado carrega seu estado.

Escopo desta varredura. Asaas/fintech tratado como evolução futura, catraca como dependente de bancada, e os cinco pontos do Método ARKE como regra comercial — conforme definido. O que sobra aqui é prontidão de *código*.

1. O que está íntegro

Verificado na varredura, não de memória.

Checagem	Resultado
Tabelas sem RLS	zero — a regra 1 do projeto está íntegra
Edge functions: repositório ↔ publicadas	eram 26 = 26 . Após a limpeza: 25 no repositório, 26 publicadas — falta excluir <code>parsear-dieta-pdf</code> no painel (ação de vocês)
Migrations no repositório	114
Cron jobs ativos	8 (ativação, barreira de rotina, SLA, engajamento, acolhimento, financeiro, MRR)
Testes automatizados	162 — 116 no app, 46 no gateway (14 de borda da catraca entraram depois)
Funções <code>get_superadmin_*</code>	13 de 13 checam o papel por dentro — sem escalada de privilégio
Dados de homologação	1 organização, 10 alunos ativos, 0 CPFs sujos

2. Pontas soltas

2.1 O `.maybeSingle()` voltou — cinco vezes RESOLVIDO

Eu havia dito que esse padrão merecia uma varredura dedicada e não a tinha feito. Fiz agora. O defeito é sempre o mesmo: consultar `organization_members` por `user_id` sem fixar a organização. Quem tem vínculo ativo em duas academias faz a consulta falhar e leva 403.

Função	Quebra quando	Gravidade
<code>anonimizar-aluno</code>	gestor com 2 vínculos — caminho de LGPD	Alta
<code>gerar-link-ativacao</code>	aluno com 2 vínculos não recebe o link de ativação	Alta
<code>cadastrar-membro-equipe</code>	gestor com 2 vínculos não consegue cadastrar equipe	Média
<code>excluir-aluno</code>	gestor com 2 vínculos não consegue excluir	Média
<code>send-chat-push</code>	destinatário com 2 vínculos não recebe push	Média

Correção deste relatório: a varredura inicial apontou mais duas funções como defeituosas (`asaas-emitir-cobranca-b2b` e `superadmin-suporte-tenant`). Ao abrir o código para corrigir, as duas já estavam certas — têm `.order(...).limit(1)` antes do `.maybeSingle()` , o que torna a consulta segura. O grep inicial mostrava só as linhas `.eq` e escondeu o `.limit` . **São 5 defeitos reais, não 7.**

O pior da lista era o `anonimizar-aluno` : o defeito atingia justamente o caminho de conformidade. As cinco foram corrigidas com três receitas diferentes, conforme o que cada função sabe — quando a organização do alvo já é conhecida, o portão passa a perguntar direto por ela, o que elimina a ambiguidade em vez de desempata-la. Todas publicadas.

2.2 O gêmeo morto do parser RESOLVIDO NO REPO

`parsear-dieta-pdf` estava publicado e versionado sem **nenhum chamador** — só `parse-dieta-pdf` é usado (`AdminDietas.tsx:363`). É exatamente o tipo de duplicata que atrasou o diagnóstico quando o parser quebrou em produção.

Removido do repositório. A exclusão da função publicada é feita pelo painel do Supabase e fica para vocês — é o mesmo caminho usado para a `qa-bootstrap-temp` em setembro. Enquanto não for feita, repositório e ambiente ficam com um de diferença.

2.3 Higiene de segurança (Supabase advisors) RESOLVIDO

Achado	Natureza
14 funções de trigger expostas como RPC para <code>anon</code> e <code>authenticated</code>	Não é buraco — chamar fora do contexto de trigger dá erro — mas é superfície desnecessária. Uma delas (<code>exigir_limite_alunos</code>) foi introduzida agora.
9 de 13 <code>get_superadmin_*</code> chamáveis por <code>anon</code>	As outras 4 têm <code>revoke</code> . Todas se protegem por dentro, então não há vazamento — mas a defesa em profundidade está desigual.
<code>limite_padrao_plano</code> com <code>search_path</code> mutável	WARN do advisor. Função introduzida agora.
Proteção contra senha vazada desabilitada	Configuração do Auth. Um toggle no painel do Supabase — ação sua , não de código.

2.4 Pendência antiga CAUSA PROVADA

A causa da orfandade foi provada em 21/09. As chaves estrangeiras são ON DELETE CASCADE e estão validadas, e ainda assim 18 linhas sobreviveram à exclusão dos pais em setembro. A hipótese era `session_replication_role = 'replica'`, que desliga os triggers de FK. Testada em transação revertida: a mesma exclusão gera **0 órfãos** com os triggers ligados e **órfãos em 5 tabelas** com eles desligados — `modelos_treino=5`, `modelos_dieta=5`, `precificacao=3`, `alunos=1`, `status_historico=1`, que é o seed exato de uma organização nova e bate com o inventário de setembro.

O cascade nunca esteve quebrado. Como a causa é operacional, a defesa também é:

`public.verificar_orfaos()` varre todas as FKs que apontam para `organizations` e conta o que ficou apontando para o vazio, sem lista mantida à mão. **Rodar depois de qualquer exclusão de tenant feita fora do produto.**

3. Placar

Módulo	Antes	Agora	O que segura
Núcleo — auth, RLS, multitenancy	95%	98%	causa da orfandade explicada e detectável
App do aluno	92%	92%	—
Metodologia — prescrição, fases, check-in	90%	90%	os cinco pontos em decisão comercial
Nutrição / parser de PDF	90%	95%	excluir o gêmeo no painel
Onboarding & importação	88%	95%	—
LGPD	85%	95%	—
Higiene de segurança	80%	93%	toggle de senha vazada
Catraca	75%	80%	bancada · ponte .NET
Fintech	—	—	fora de escopo por decisão

~92%

Prontidão geral de código, depois da execução · era ~85% na varredura da manhã e 58% (com catraca) / 72% (sem) na primeira auditoria
Julgamento ponderado, não medição — o que é medido são os números da seção 1.

4. O que foi executado e o que sobrou

- FEITO** **Varredura do** `.maybeSingle()` — 5 funções corrigidas e publicadas, com três receitas conforme o que cada uma sabe. Duas das sete apontadas já estavam corretas. De quebra, `cadastrear-membro-equipe` passou a validar CPF como a `convidar-membro` já fazia — antes o gestor veria o erro cru da constraint.
- FEITO NO REPO** **Encerrar o** `parsear-dieta-pdf` — removido do repositório; a exclusão da função publicada é pelo painel e fica com vocês.
- FEITO** **Advisors fechados** — 14 triggers e 9 RPCs de superadmin sem EXECUTE para `anon`, `search_path` fixo. O revoke em bloco pega automaticamente as próximas funções de trigger que alguém criar. Verificado contra o banco que revogar EXECUTE **não** impede o disparo dos triggers. **PENDENTE** o toggle de senha vazada, no painel do Supabase — ação de vocês.
- FEITO** **Testes de borda do receptor Control ID** — 14 testes novos: payload malformatado, `user_id` não numérico ou zero, identificador de 5.000 caracteres, campos desconhecidos de firmware novo, nuvem caindo no meio de uma sequência e rajada de 10 leituras simultâneas. A regra que todos verificam é a mesma: **na dúvida, trava**.
- FEITO** **Orfandade explicada** — reproduzida em transação revertida, sem precisar de branch. A causa é `session_replication_role = 'replica'`, e agora existe `verificar_orfaos()` para conferir depois de qualquer exclusão de tenant feita fora do produto.

Sobrou para vocês, e é tudo de painel ou de terceiro: excluir a função `parsear-dieta-pdf` publicada, ligar a proteção contra senha vazada no Auth, e — do lado da catraca — baixar a SDK da Topdata, fazer o cadastro de integrador e pedir o Kit Integrador.

5. Fora do escopo desta varredura

Frente	Situação
Fintech / Asaas	Tratada como evolução futura. A integração está configurada e funcionando; o que ficou para depois é a rede de segurança de inadimplência B2C e a reconciliação automática gateway ↔ banco.
Catraca Control iD	Implementada e testada com os payloads literais da documentação do fabricante. Falta bancada: timing do giro, sentido de liberação, ergonomia do cadastro de digital e leitura em dedo de academia.
Catraca Topdata	Arquitetura fechada e lado do ARKE pronto. Falta a ponte <code>ArkeInnerBridge</code> em .NET — especificação em <code>docs/PONTE_TOPDATA.md</code> . Destrava com SDK + Kit Integrador, sem precisar de academia.
Henry / Dimep	Sem documentação de integração pública. Conexão vira parte do processo comercial na implantação.
Cinco pontos do Método ARKE	Check-in "com dificuldade" sem dor que não avisa ninguém · barreira de rotina que não filtra por adesão · teto de 80 pontos do Essencial · fase que trava em B.A.S.E.® sem lembrete · UTC das rotinas. São decisões de regra interna, não defeitos.

Gerado em 21/09/2026 a partir de varredura ao vivo do repositório e do projeto Supabase `jbkrxrfdmrky1drrdpq`. Os números da seção 1 são medidos; as notas da seção 3 são julgamento ponderado e devem ser lidas como tal.